

Fiche pédagogique

Comment sont construits les scores du modèle qualitatif de cascade DORA

Kélian Kaddouri

15 juillet 2026

Idée centrale. On n'évalue pas un *ensemble* de piliers DORA, mais une *chaîne ordonnée* d'effondrement. Une cascade qui suit une direction causale plausible (amont → aval, gouvernance → conséquences) est un vrai emballement systémique : plus **probable** et plus **grave**. Le même ensemble pris à l'envers est rare et peu grave. **L'ordre pilote donc le verdict.**

1 Les cinq piliers et les trois tables de jugement

Les cinq piliers de DORA (Règlement UE 2022/2554 [1]) sont indexés de 1 à 5 : P1 gouvernance & gestion du risque TIC ; P2 gestion des incidents ; P3 tests de résilience (TLPT) ; P4 gestion du risque lié aux tiers ; P5 partage d'informations.

Tout le modèle repose sur **trois barèmes d'expert** [6, 7], et rien d'autre. Aucune valeur n'est mesurée : ce sont des jugements *ordonnés*, dont seule la **hiérarchie** est défendable — une matrice de risque ne doit jamais être lue plus finement que son ordre [5] (la sensibilité, § 4, montre que les décimales exactes importent peu). Le principe même d'un score *criticité* = $f(\text{probabilité}, \text{gravité})$ est celui des référentiels de gestion des risques [3, 4].

Table	Rôle	Ancrage logique + DORA
ROOT[p]	Propension du pilier p à <i>amorcer</i> une cascade.	P1= 1,0 (fondation gouvernance, responsabilité de l'organe de direction, chap. II) ; P4= 0,9 (surface d'attaque externe, cloud) ; P5= 0,3 (rarement déclencheur).
TRANS[a][b]	Force dirigée « a entraîne b », asymétrique .	P1→tout fort ; tout→P1 faible ; P4→P2= 0,8. C'est l'asymétrie qui fait que l'ordre compte.
GBASE[p]	Gravité intrinsèque du pilier s'il tombe seul.	P4= 7 : contagion systémique (cadre de supervision des tiers critiques) ; P1= 6 (fondation) ; P5= 1 : partage volontaire (art. 45) ⇒ le moins critique.

Table 1. Les seuls chiffres d'entrée du modèle et leur justification.

D'où viennent ces trois barèmes ? Les *valeurs* sont un jugement d'expert ancré sur la structure de DORA. Les *concepts*, eux, sont trois primitives standard de l'analyse de risque, ici recombinaées :

- **ROOT** instancie l'événement *initiateur* de l'analyse probabiliste de risque et le *nœud-graine* des modèles de cascade, dont l'influence se mesure par la taille attendue de la propagation [12, 13].
- **TRANS** est une *matrice d'influence dirigée* : ses entrées sont des forces d'entraînement, non des probabilités (les lignes ne somment pas à 1). Normalisée ligne à ligne, elle devient le *noyau de transition* d'une chaîne de Markov et rejoint les réseaux bayésiens [14], les probabilités d'activation d'arête des modèles de cascade [13] et les matrices d'influence du risque systémique [15].
- **GBASE** est l'axe de *sévérité intrinsèque* par composant : la gravité de l'AMDEC [16] et le score de base CVSS [17].

Réunies, ces trois briques sont le **triplet du risque** de Kaplan & Garrick [12] : *quel scénario (ROOT, TRANS), avec quelle probabilité, pour quelle conséquence (GBASE)*. **L'apport propre** de ce modèle n'est aucune de ces briques, mais leur mise en *dépendance de l'ordre* — le même ensemble de piliers étant noté différemment selon la direction de la chaîne.

2 Construction des deux dernières colonnes

Colonne « Probabilité conceptuelle » (rappel, préalable)

La probabilité part du pilier amorceur et se dégrade à chaque maillon de la chaîne :

$$p = \text{round}\left(10 \times \text{ROOT}[\text{départ}] \times \prod_{\text{maillons } a \rightarrow b} \text{TRANS}[a][b]\right), \quad p \in [1, 10]. \quad (1)$$

Une chaîne longue est mécaniquement plus rare (chaque facteur < 1). Ce p est une **cotation ordinale** sur $[1, 10]$, non une probabilité normalisée : il *classe* les ordres, comme le recommande Cox (2008) [5] pour une matrice de risque, sans prétendre se sommer à 1. La normalisation en vraie probabilité conditionnelle est traitée à part.

Lecture récursive (structure d'arbre). Ce produit n'est pas arbitraire : il a une structure d'**arbre**. La probabilité d'un ordre de n piliers se *construit* à partir de son préfixe de $n - 1$ piliers, en multipliant par le seul maillon ajouté :

$$p(a \rightarrow b \rightarrow c) = \underbrace{\text{ROOT}[a] \times \text{TRANS}[a][b]}_{p(a \rightarrow b)} \times \text{TRANS}[b][c] = p(a \rightarrow b) \times \text{TRANS}[b][c]. \quad (2)$$

On engendre ainsi tous les ordres en insérant le pilier suivant à chaque position, suivant la récurrence $N_n = n N_{n-1}$ (2, 6, 24, 120 ordres pour 5 piliers). La figure 1 déroule cet arbre sur l'exemple à trois piliers, avec les valeurs réelles du modèle : partir de P1 (gouvernance) est la seule racine vraiment probable ; toute branche amorcée en aval retombe au plancher.

Colonne « Gravité conceptuelle »

La gravité = *étendue des dégâts* **amplifiée ou amortie** par la cohérence causale de l'ordre. Elle se lit en trois temps :

L'arbre récursif des ordres : la proba se construit lien par lien

Exemple à 3 piliers (P1-P2-P3). Chaque feuille est un ordre ; sa proba est le produit ROOT × transitions le long du chemin.

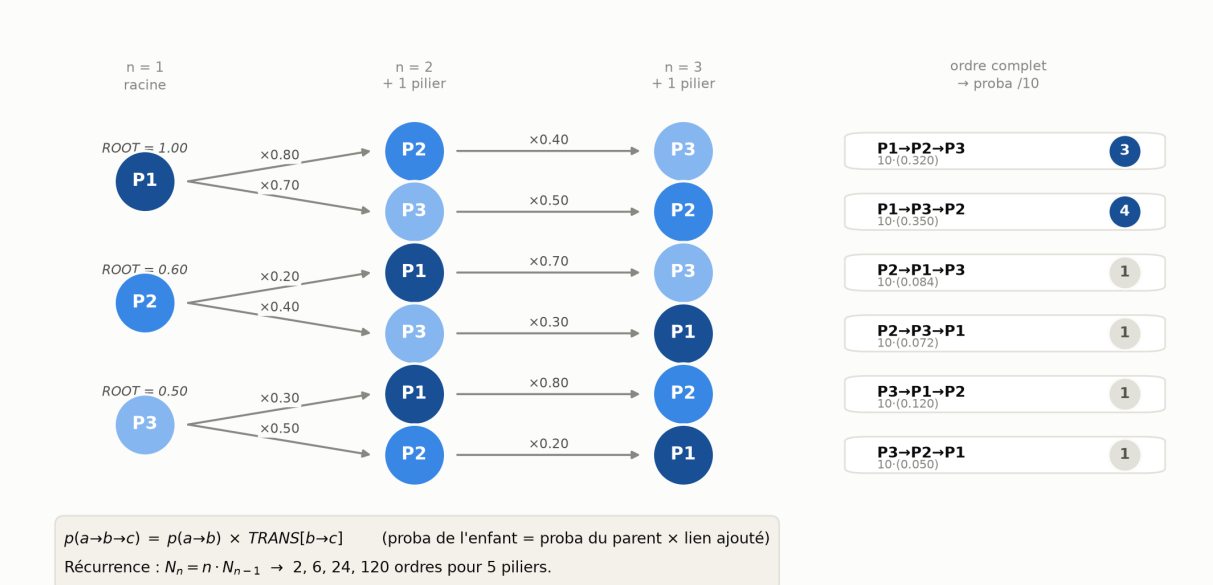


Figure 1. La probabilité se construit lien par lien le long de l'arbre des ordres : proba de l'enfant = proba du parent × transition ajoutée. L'asymétrie de TRANS (p.ex. P1→P3 à 0,70 contre P3→P1 à 0,30) est ce qui sépare les verdicts. *N.B.* seule la **probabilité** se décompose ainsi ; la gravité, elle, dépend de l'ensemble des piliers présents (étendue) et n'est pas multiplicative le long de l'arbre.

$$\text{étendue} = \min\left(10, \max(\text{GBASE}) + 0,40 \times \sum_{\text{autres piliers}} \text{GBASE}\right) \quad (3)$$

$$\text{cohérence} = \text{moyenne}(\text{TRANS}[\text{maillons}]) \in [0, 1] \quad (4)$$

$$\text{amplification} = 0,5 + 0,8 \times \text{cohérence} \in [0,5, 1,3] \quad (\text{bornes théoriques}) \quad (5)$$

$$g = \text{round}(\text{étendue} \times \text{amplification}), \quad g \in [1, 10]. \quad (6)$$

Le pire pilier donne le socle ; les autres n'ajoutent que 40 % chacun. Avec les valeurs du modèle (TRANS de 0,10 à 0,80), la cohérence effective borne l'amplification à environ $[\times 0,6, \times 1,1]$: un ordre plausible emballe (vers $\times 1,1$), un ordre absurde amortit (vers $\times 0,6$, pannes quasi indépendantes). Les extrêmes $\times 0,5$ et $\times 1,3$ ne sont pas atteints.

Colonne « Criticité »

$$\text{criticité} = \text{round}(\sqrt{p \times g}).$$

La racine ramène le produit $p \times g$ (le *RPN* de l'AMDEC [16]) sur la même échelle de 1 à 10 que p et g , et **comprime** les valeurs : il faut être à la fois assez probable *et* assez grave [8]. Le *classement* des scénarios reste celui du produit $p \times g$ (la racine est monotone) ; ce que la racine change, c'est l'échelle. Qu'aucun scénario n'atteigne « Extrême » au calage de base n'est donc pas une propriété de la moyenne géométrique, mais une conséquence du calage (produit maximal, arrondi, plage $[1, 10]$) : la sensibilité (plus bas) montre que ce plafond est **fragile**.

	1 → 2 <i>gouvernance</i> ⇒ <i>incident</i>	2 → 1 <i>incident</i> ⇒ <i>gouvernance</i>
Étendue	$6 + 0,4 \times 4 = \mathbf{7,6}$	<i>identique</i> = 7,6
Cohérence	TRANS[1][2] = 0,80	TRANS[2][1] = 0,20
Amplification	$0,5 + 0,8 \times 0,80 = \mathbf{1,14}$	$0,5 + 0,8 \times 0,20 = \mathbf{0,66}$
Gravité	$7,6 \times 1,14 \rightarrow \mathbf{9}$ (Critique)	$7,6 \times 0,66 \rightarrow \mathbf{5}$ (Modérée)
Probabilité	$10 \times 1,0 \times 0,80 \rightarrow \mathbf{8}$ (Probable)	$10 \times 0,6 \times 0,20 \rightarrow \mathbf{1}$ (Très rare)
Criticité	$\sqrt{8 \times 9} = 8,49 \rightarrow \mathbf{8}$ (Majeure)	$\sqrt{1 \times 5} = 2,24 \rightarrow \mathbf{2}$ (Faible)

Table 2. L'étendue est *identique* dans les deux sens (mêmes piliers). Tout l'écart de verdict (Majeure vs Faible) vient de la seule **cohérence causale de l'ordre**.

Exemple travaillé : le même ensemble {P1, P2}, deux sens

3 Justification des scores absolus

Trois points à défendre devant le jury :

1. **Ce sont des hypothèses, pas des mesures.** La valeur d'un tel modèle (comme une matrice de risque ORSA / Pilier 2 sous Solvabilité II [2]) est sa *cohérence interne* et sa *traçabilité*, pas une prétendue précision.
2. **Seule la hiérarchie est revendiquée.** Le résultat défendable n'est pas « 1 → 2 vaut 8 » mais « un ordre causalement cohérent est plus critique que son inverse », vrai tant que TRANS est asymétrique, quelles que soient les décimales.
3. **Les paramètres de forme (0,40, 0,5, 0,8) sont les moins ancrés** (purements des choix de modélisation), mais la § 4 montre qu'ils ne portent pas la conclusion.

À quelle famille de méthode cet instrument appartient-il ? Il est original, mais non isolé. Le scoring multiplicatif d'ordinaux est celui de l'**AMDEC** et de son *Risk Priority Number* $RPN = \text{Gravité} \times \text{Occurrence} \times \text{Détection}$ [16] ; la décomposition *dirigée* d'une défaillance en chaîne est celle des **arbres d'attaque** [18] et des arbres de défaillance de l'analyse probabiliste de risque [19]. Notre modèle se distingue de tous par un seul trait : la **dépendance à l'ordre**, absente de l'AMDEC (qui ignore la séquence) comme de la matrice de risque.

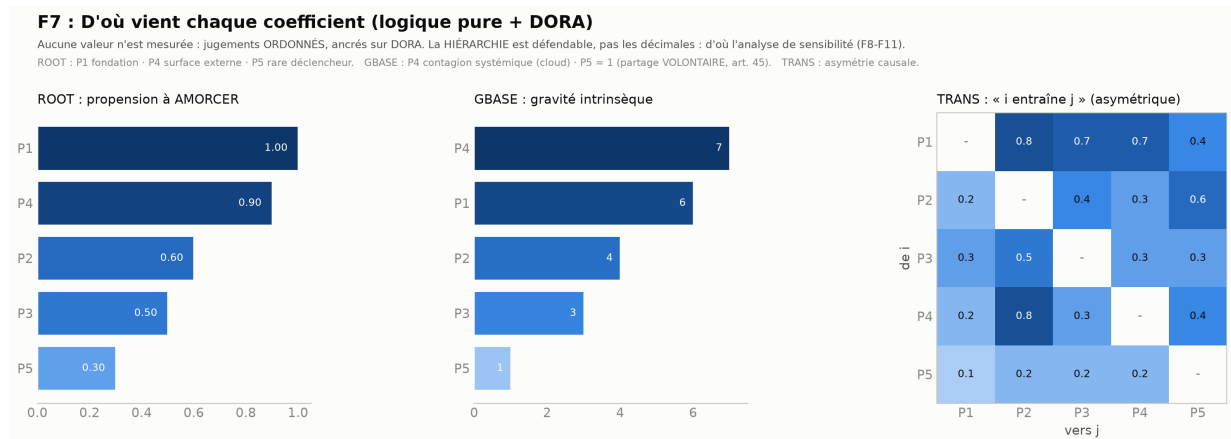


Figure 2. D'où vient chaque coefficient : hiérarchie ordonnée, ancrée sur la structure de DORA.

4 Robustesse : ce qui tient, ce qui ne tient pas

On ne nie pas que « tout dépend des valeurs » : on le **teste**. On perturbe tous les coefficients autour de leur base sur **3 000 tirages** Monte-Carlo et on regarde si les *conclusions* survivent. C'est une **analyse de sensibilité globale**, où l'on neutralise une hypothèse à la fois pour mesurer ce qu'elle porte [9].

Conclusion	Statut	Résultat
L'ordre renverse le verdict	robuste	91% des paires en moyenne ; jamais < 80% (100 % des tirages)
Classement des pires cascades	robuste	un scénario du Top-15 y reste dans 84% des tirages
Plafond « jamais Extrême »	fragile	franchi dans 55% des tirages $\Rightarrow$ propriété du calage, à ne pas sur-vendre

Table 3. La distinction essentielle : deux conclusions robustes, une fragile.

Qu'est-ce qui porte le résultat ? En neutralisant chaque hypothèse (coefficients rendus égaux), on mesure ce qui reste de l'effet d'ordre (amplitude moyenne $|\Delta \text{criticité}|$ entre un ordre et son inverse) :

$$\underbrace{2,90}_{\text{modèle complet}} \longrightarrow \underbrace{0,90}_{\text{sans asymétrie TRANS}} ; 2,50 \text{ (sans écart ROOT)} ; 2,30 \text{ (sans écart GBASE)} ; 0,00 \text{ (sans les trois)}.$$

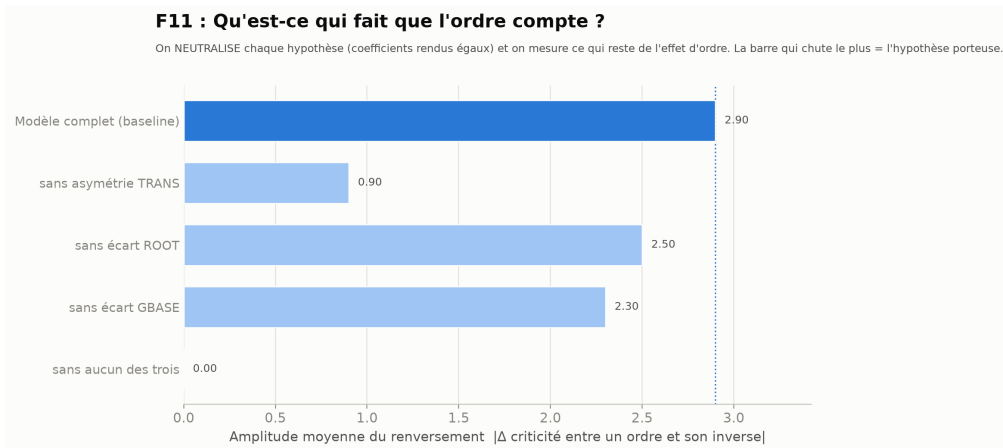


Figure 3. Neutraliser l'**asymétrie causale (TRANS)** efface l'essentiel de l'effet (−69%) : c'est *elle* qui porte le résultat. ROOT et GBASE ne font qu'affiner.

Conclusion. La seule hypothèse forte à défendre est la **direction causale entre piliers** (TRANS asymétrique) — l'idée qu'une attaque suit une chaîne orientée, de l'amont vers l'aval [10], et se propage de proche en proche comme une contagion [11]. À partir d'elle, deux résultats tiennent quel que soit le calage : *l'ordre renverse le verdict* et *le classement des cascades les plus critiques*. Le plafond de criticité, lui, dépend des chiffres et n'est pas présenté comme un résultat. Connaître et énoncer soi-même cette limite est ce qui distingue le modèle.

5 Sources des concepts mobilisés

Le modèle qualitatif combine un socle réglementaire (DORA, Solvabilité II) et des méthodes établies de gestion des risques. Aucun de ces concepts n'est original ; l'apport est leur *articulation* autour de l'ordre causal. Le tableau ci-dessous relie chaque brique à sa source.

Concept dans la fiche	Section	Source
Cinq piliers, gouvernance, tiers, partage volontaire	§1	Règlement UE 2022/2554 (DORA) [1]
Score <i>criticité</i> = $f(\text{probabilité}, \text{gravité})$	§1–2	ISO 31000 [3] ; ISO/IEC 27005 [4]
Ne lire une matrice de risque que par son <i>ordre</i>	§1, §4	Cox (2008) [5]
Trois barèmes = jugement d'expert structuré	§1	Cooke (1991) [6] ; O'Hagan et coll. (2006) [7]
ROOT = événement initiateur / nœud-graine	§1	Kaplan & Garrick (1981) [12] ; Kempe et coll. (2003) [13]
TRANS = matrice de transition / influence dirigée	§1–2	Pearl (1988) [14] ; Kempe et coll. (2003) [13] ; Battiston et coll. (2012) [15]
GBASE = axe de sévérité intrinsèque par composant	§1	AMDEC / IEC 60812 [16] ; CVSS [17]
Les trois barèmes ensemble = triplet du risque	§1	Kaplan & Garrick (1981) [12]
Famille de méthode : RPN multiplicatif, arbres d'attaque	§4	IEC 60812 [16] ; Schneier (1999) [18] ; Vesely et coll. (1981) [19]
Analogie matrice ORSA / Pilier 2	§4	Directive Solvabilité II 2009/138 [2]
Moyenne géométrique pénalisant le déséquilibre	§2	Grabisch et coll. (2009) [8]
Ordre causal dirigé / chaîne d'attaque orientée	§1–2, §5	Hutchins et coll. (2011) [10]
Cascade / contagion entre composants	intro, §5	Hillairet & Lopez (2021) [11]
Analyse de sensibilité globale (Monte-Carlo, knockout)	§5	Saltelli et coll. (2008) [9]

Table 4. Chaque concept et sa source. La contribution de la fiche n'est pas un concept neuf, mais leur *combinaison* autour de la direction causale entre piliers.

Références

- [1] Parlement européen et Conseil de l'Union européenne. *Règlement (UE) 2022/2554 sur la résilience opérationnelle numérique du secteur financier (DORA)*. Journal officiel de l'Union européenne, 2022.
- [2] Parlement européen et Conseil de l'Union européenne. *Directive 2009/138/CE (Solvabilité II)*, art. 45 (ORSA). 2009.
- [3] Organisation internationale de normalisation. *ISO 31000 :2018 — Management du risque : lignes directrices*. Genève, 2018.
- [4] Organisation internationale de normalisation. *ISO/IEC 27005 — Gestion des risques liés à la sécurité de l'information*. Genève.
- [5] Cox, L. A. Jr. « What's Wrong with Risk Matrices ? » *Risk Analysis*, 28(2) :497–512, 2008.

- [6] Cooke, R. M. *Experts in Uncertainty : Opinion and Subjective Probability in Science*. Oxford University Press, 1991.
- [7] O'Hagan, A., Buck, C. E., Daneshkhah, A. et coll. *Uncertain Judgements : Eliciting Experts' Probabilities*. Wiley, 2006.
- [8] Grabisch, M., Marichal, J.-L., Mesiar, R. et Pap, E. *Aggregation Functions*. Cambridge University Press, 2009.
- [9] Saltelli, A., Ratto, M., Andres, T. et coll. *Global Sensitivity Analysis : The Primer*. Wiley, 2008.
- [10] Hutchins, E. M., Cloppert, M. J. et Amin, R. M. « Intelligence-Driven Computer Network Defense Informed by Analysis of Adversary Campaigns and Intrusion Kill Chains ». *Leading Issues in Information Warfare & Security Research*, 1 :80, 2011.
- [11] Hillairet, C. et Lopez, O. « Propagation of cyber incidents in an insurance portfolio ». *Scandinavian Actuarial Journal*, 2021.
- [12] Kaplan, S. et Garrick, B. J. « On the Quantitative Definition of Risk ». *Risk Analysis*, 1(1) :11–27, 1981.
- [13] Kempe, D., Kleinberg, J. et Tardos, É. « Maximizing the Spread of Influence through a Social Network ». *Proc. 9th ACM SIGKDD*, p. 137–146, 2003.
- [14] Pearl, J. *Probabilistic Reasoning in Intelligent Systems : Networks of Plausible Inference*. Morgan Kaufmann, 1988.
- [15] Battiston, S., Puliga, M., Kaushik, R., Tasca, P. et Caldarelli, G. « DebtRank : Too Central to Fail ? Financial Networks, the FED and Systemic Risk ». *Scientific Reports*, 2 :541, 2012.
- [16] Commission électrotechnique internationale. *IEC 60812 — Analyse des modes de défaillance et de leurs effets (AMDEC)*. 2018.
- [17] Forum of Incident Response and Security Teams (FIRST). *Common Vulnerability Scoring System (CVSS) — Specification Document*.
- [18] Schneier, B. « Attack Trees ». *Dr. Dobb's Journal*, 24(12) :21–29, 1999.
- [19] Vesely, W. E., Goldberg, F. F., Roberts, N. H. et Haasl, D. F. *Fault Tree Handbook (NUREG-0492)*. U.S. Nuclear Regulatory Commission, 1981.